

Penetration Testing Project (VAPT – Phase

2) Company: Elantrach Corp

Problem Statement:

Transitioning from Vulnerability Assessment to Penetration Testing

Following the Vulnerability Assessment phase, Elantrach's management has approved a **controlled penetration test** to validate whether identified vulnerabilities are **actually exploitable** and to understand the **real business impact** of a potential attack.

This penetration test will simulate a **real-world attacker** attempting to gain unauthorized access, escalate privileges, and access sensitive systems and data.

Penetration Testing Project Objectives

You are required to:

- Exploit confirmed vulnerabilities safely
- Demonstrate real impact (access, control, data exposure)
- Perform limited post-exploitation activities
- Produce a **professional penetration testing report** aligned with global standards

Penetration Testing Scope

In-Scope:

- **Target Machine:** Metasploitable 2 VM
- Network services exposed by the target
- Web applications hosted on the target
- Database services accessible via web or network

Out-of-Scope:

- Denial-of-Service attacks
- Destructive payloads
- Attacks beyond the lab environment

Phase 1: Exploitation

A. Network Exploitation (Minimum: 5 Vulnerabilities)

You must exploit **at least five (5) network-based vulnerabilities** discovered during the vulnerability assessment.

Common Exploitable Services on Metasploitable 2:

- FTP (vsftpd backdoor)
- SMB (Samba)
- Telnet
- SSH (weak credentials)
- DistCC
- RSH
- PostgreSQL
- NFS

Tooling:

- **Manual exploitation** where applicable
- Metasploit Framework
- Netcat etc...

Example of how to perform Exploitation:

1. Identify vulnerable service and port
2. Select appropriate exploit module in Metasploit (msfconsole)
3. Configure target IP and payload
4. Launch exploit
5. Obtain shell or session

Deliverables:

- Successful remote shell or meterpreter session
- Proof of unauthorized system access
- Properly named Screenshots for proof

B. Web Application Exploitation (Minimum: 4 Vulnerabilities) You must exploit

at least four (4) web application vulnerabilities hosted on Metasploitable 2. **Common**

Vulnerabilities:

- SQL Injection
- Command Injection
- File Inclusion (LFI/RFI)
- Weak Authentication
- XSS (Reflected/Stored)
- Insecure File Upload

Tools:

- **OWASP ZAP**
- Browser
- Burp Suite (optional)

Example of the Workflow:

1. Identify vulnerable endpoint
2. Manually confirm vulnerability
3. Exploit to extract data or gain execution
4. Capture evidence (screenshots, output)

Expected Deliverables:

- Extracted data, command execution, or authentication bypass

C. Database Exploitation (Minimum: 1 Vulnerability)

You must exploit **at least one database vulnerability** using **SQLMap**.

Tool:

- **SQLMap**

Target:

- Web application with injectable parameter

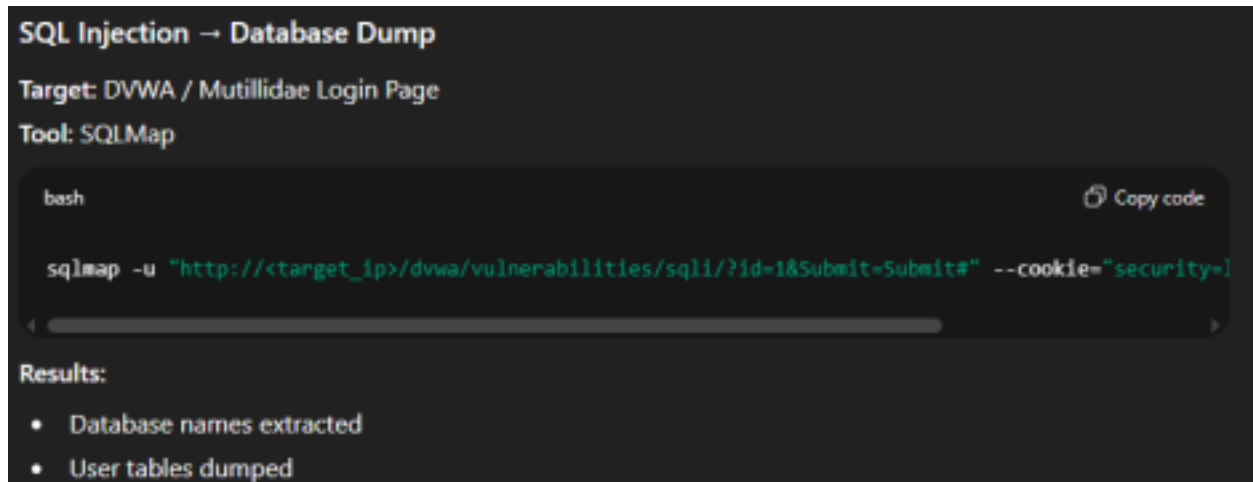
Example of How to exploit (Workflow):

1. Identify SQL injection point
2. Confirm vulnerability manually or via ZAP
3. Use SQLMap to:

- Enumerate databases
- Extract tables and data
- Identify DB user privileges

Expected Outcome:

- Database names
- Table structures
- Screenshots and outputs of extracted records.



The screenshot shows a terminal window with the title "SQL Injection → Database Dump". Below the title, it says "Target: DVWA / Mutillidae Login Page" and "Tool: SQLMap". A code editor shows the command: `sqlmap -u "http://<target_ip>/dvwa/vulnerabilities/sql1/?id=1&Submit=Submit#" --cookie="security=]`. Below the code editor, under the heading "Results:", there are two bullet points: "Database names extracted" and "User tables dumped".

Use the SQLMap guide document on the classroom for better understanding

Phase 2: Post-Exploitation

You must perform **at least two (2) post-exploitation activities** after successful exploitation.

Allowed Post-Exploitation Activities:

Choose any **two or more** of the following:

1. Privilege Escalation

- Attempt to escalate from low-privilege user to root
- Identify misconfigurations or weak permissions

Method:

```
uname -a
sudo -l
```

Result:

- Root privileges achieved using misconfigurations

2. Credential Harvesting

- Extract stored credentials
- Access password files or configuration files

Actions:

```
cat /etc/passwd  
cat /etc/shadow
```

- Extract user credentials
- Create backdoor user for persistence

3. System Enumeration

- Identify:
 - Installed software
 - Running processes
 - Network connections
 - User accounts

4. Persistence (*Conceptual / Demonstration Only*)

- Explain how persistence *could* be achieved
- No destructive or permanent persistence required

Expected Deliverables:

- Demonstrated attacker capabilities post-compromise
- Clear evidence of impact beyond initial access
- Screenshots and outputs of results

Phase 3: Reporting (Global Standards Format)

This phase is **mandatory** and **very important** (ensure you use resources in the google classroom, research online and ask questions).

You must produce a **professional Penetration Testing Report** that aligns with **global security reporting standards** (if you are not sure, ask questions after reviewing the penetration testing reporting resource on the classroom).

Reporting Structure (Required)

1.Executive Summary

- High-level overview (non-technical)
- Overall risk posture
- Key findings and business impact

2.Scope & Methodology

- Target details
- Tools used
- Testing approach (Black-box / White-box)
- Rules of engagement

3.Vulnerability Findings

For each vulnerability you exploit, include:

- Vulnerability Name
- Severity (Critical/High/Medium/Low)
- Description
- Proof of Concept/Exploitation (also called steps-to-reproduce)
- Impact
- Affected Assets
- Screenshots / Evidence

4. Attack Chain Narrative

- How the attack progressed:
 - Initial access

- Exploitation
- Privilege escalation
- Data access

5. Risk Rating & Prioritization

- CVSS scores (or qualitative)
- Business impact explanation
- **Risk Mapping to:**
 - OWASP Top 10
 - MITRE ATT&CK techniques
 - CVE references

6. Remediation Recommendations

- Clear, actionable fixes
- Short-term and long-term recommendations
- Remediation Roadmap:
 - Immediate actions (patching, service removal)
 - Short-term (hardening, MFA)
 - Long-term (monitoring, secure SDLC)

7. Conclusion

- Overall security posture
- Key takeaways for Elantrach
- Suggested next steps

8. Presentation

- A more summarized executive summary
- Walkthrough of the most critical vulnerabilities exploited and their impact • Screenshots of some exploitation and post-exploitation results with simple explanations • Business impact and Timed remediation steps
- Recommended number of slides: 10-15

Reporting Standards Alignment

The report should reference or align with:

- **OWASP Testing Guide**
- **PTES (Penetration Testing Execution Standard)**

Required Deliverables Summary

Phase	Deliverables
Exploitation	Evidence of 5 network, 4 web, 1 DB exploit
Post-Exploitation	Proof of at least 2 post-exploitation activities
Reporting	Full Penetration Testing Report (PDF/Doc)
Appendix	Attack flow diagram, other relevant screenshots and References